VULNERABILITY TEST REPORT

OWASP Juice Shop

Read-Only Security Assessment

Prepared By
Leah Mashego
Cybersecurity Intern
leahmashego99@gmail.com
+27815486933

14 April 2026

Executive Summary

In April, a vulnerability assessment was conducted on the OWASP Juice Shop web application. The purpose of this assessment was to identify security weaknesses in publicly accessible components of the website using passive scanning techniques.

Key Findings:

- 0 High-risk vulnerability
- 1 Medium-Risk vulnerability
- 4 Low-Risk vulnerability
- 1 Informational finding

These vulnerabilities may expose the application to risks such as information disclosure, cross-site scripting, and misconfigured security headers. Most of the identified vulnerabilities are low risk but should be addressed to improve overall security.

Introduction

A grey box security assessment was conducted on the OWASP Juice Shop web application in order to detect security-related problems. This assessment reviewed publicly accessible components to identify and document vulnerabilities.

Scope

The assessment was conducted on the publicly accessible components of the OWASP Juice Shop web application.

Testing included:

- Passive vulnerability scanning
- Security header inspection
- Service and port exposure analysis.

Tools Used

Tools used:

The following tools were used during the vulnerability assessment:

- OWASP ZAP – passive vulnerability scanning
- Nmap - open port detection
- Browser Developer Tools - HTTP header inspection
- SecurityHeaders.com - header configuration analysis

Risk Rating Classification

Vulnerabilities severities are supplied using **DREAD** framework giving an indication of their severity and are rated on a scale of five (5) to fifteen (15) using the DREAD model below.

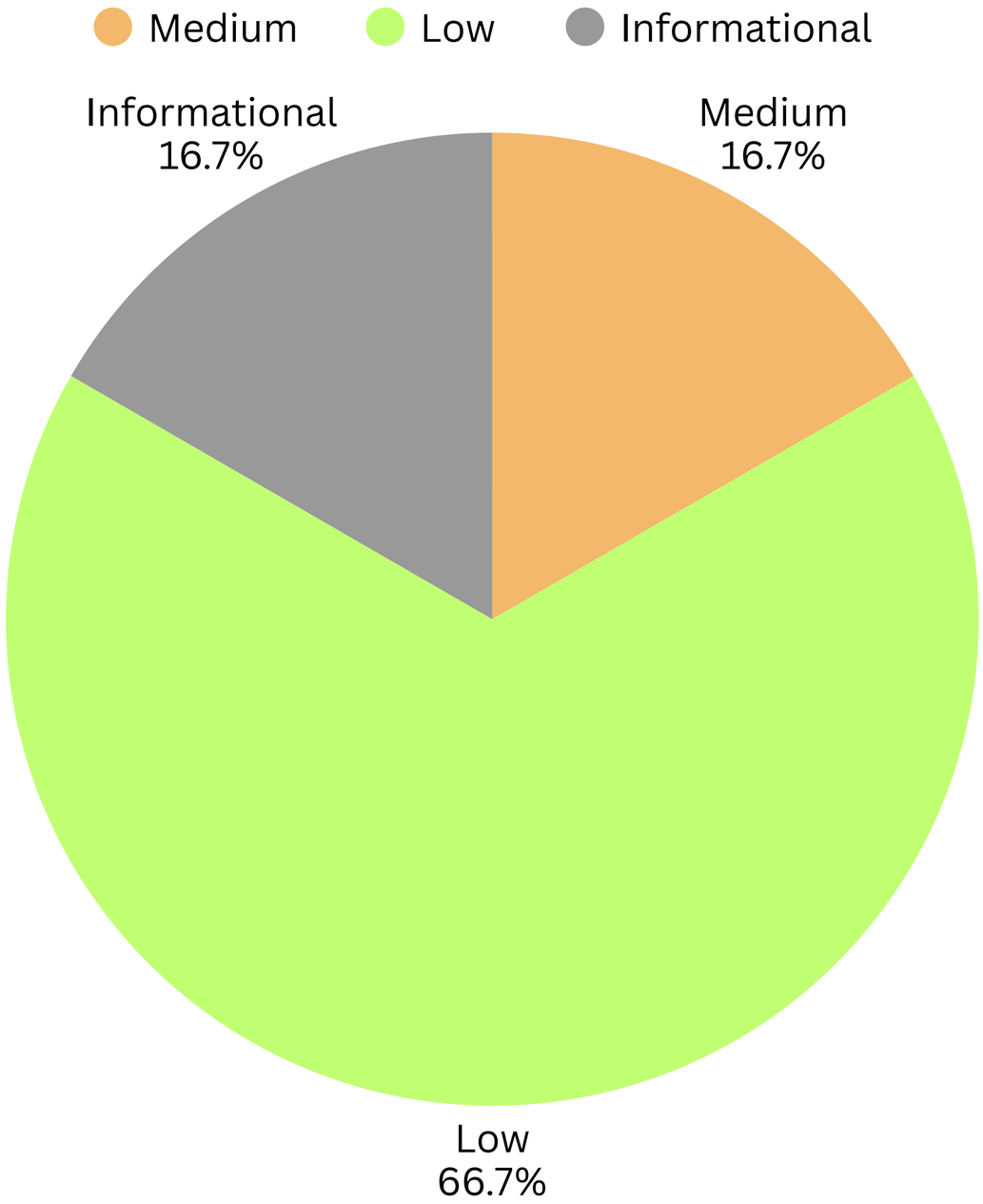
	DREAD MODEL		
Rating	**High(3)**	**Medium(2)**	**Low(1)**
Damage potential	*The attacker can subvert the security system; get full trust authorization; run as administrator; upload content.*	*Leaking sensitive information*	*Leaking trivial information*
Reproducibility	*The attack can be reproduced every time and does not require a timing window.*	*The attack can be reproduced, but only with a timing window and a particular race situation.*	*The attack is difficult to reproduce, even with knowledge of the security hole.*
Exploitability	*A novice programmer could make the attack in a fleeting time.*	*A skilled programmer could make the attack, then repeat the steps.*	*The attack requires an extremely skilled person and in-depth knowledge every time to exploit.*
Affected users	*All users, default configuration, key customers*	*Some users, non-default configuration*	*Small percentage of users, obscure feature; affects anonymous users*
Discoverability	*Published information explains the attack. The vulnerability is found in the most used feature and is very noticeable.*	*The vulnerability is in a seldom-used part of the product, and only a few users should come across it. It would take some thinking to see malicious use.*	*The bug is obscure, and it is unlikely that users will work out damage potential.*

Risk	Total
High	12 to 15
Medium	8 to 11
Low	5 to 7
Informational	0

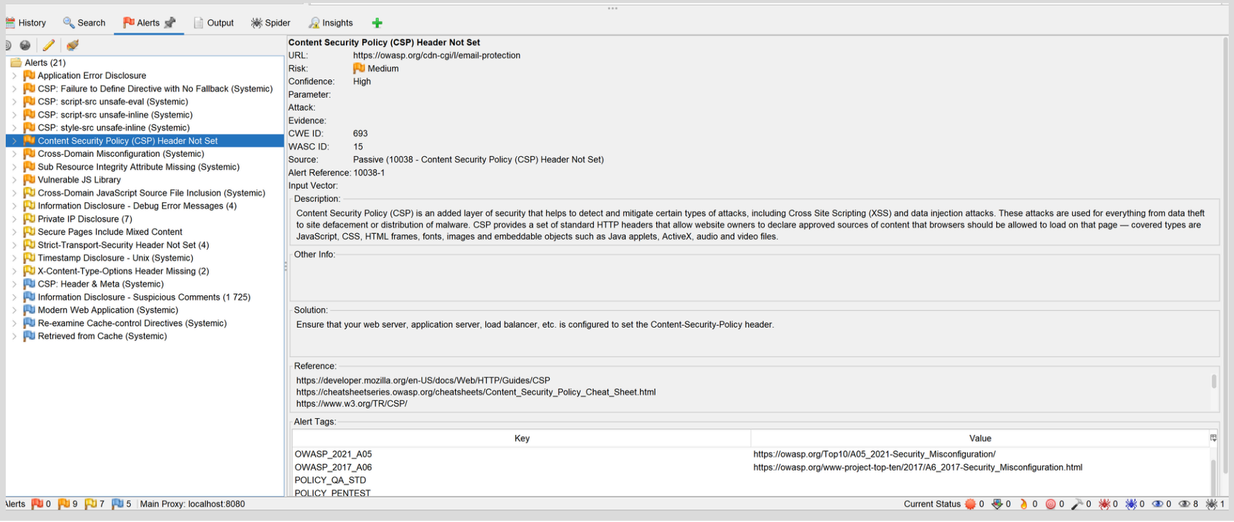
Vulnerabilities Overview Table

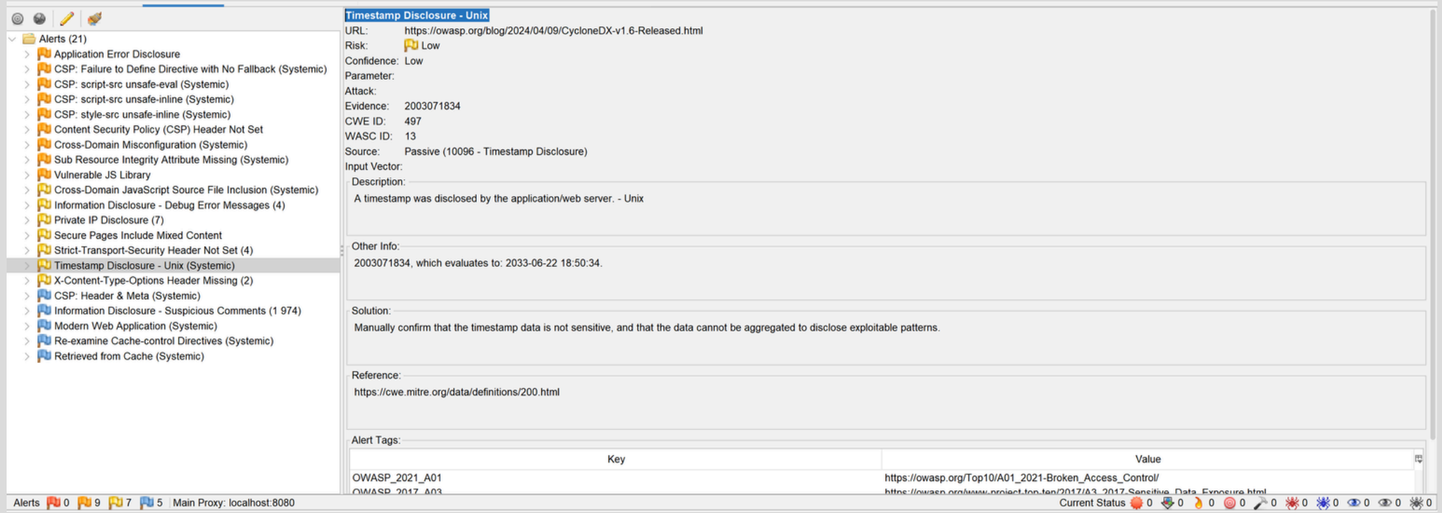
Vulnerabilities grouped by risk severity	
High	0
Medium	1
Low	4
Informational	1
Total	**6**

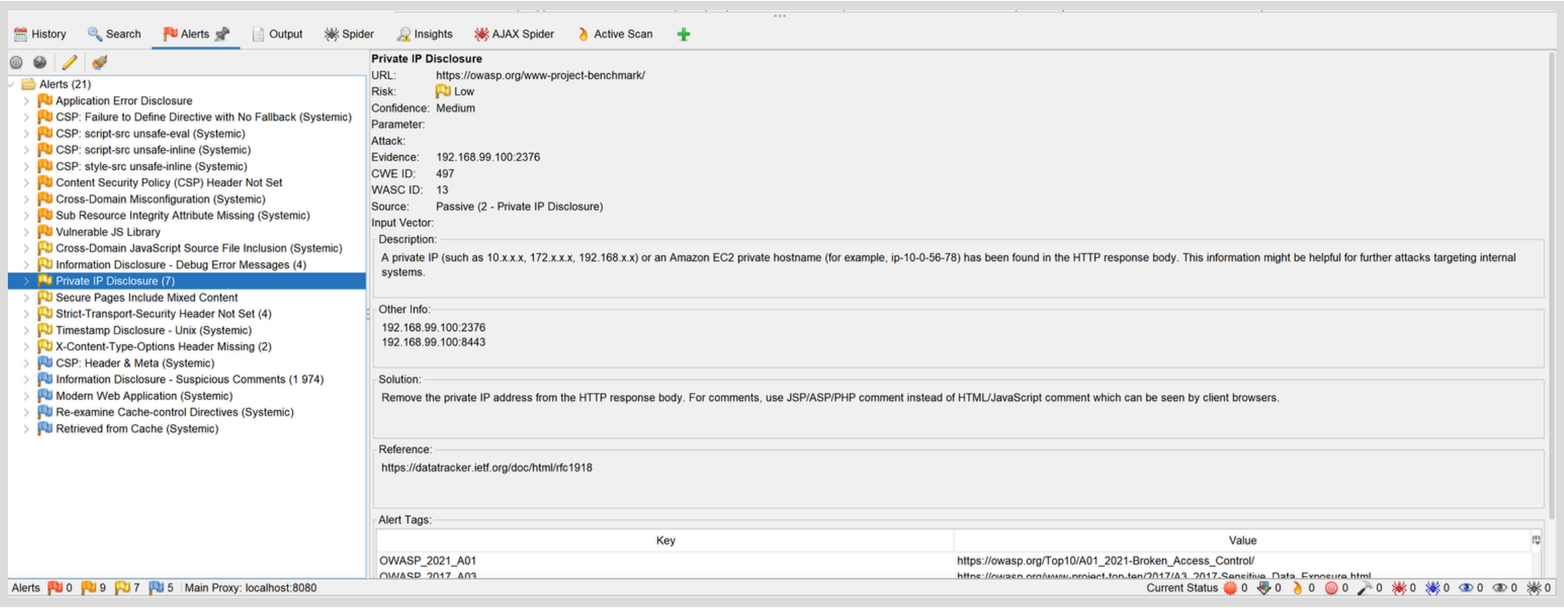
Vulnerability Risk Distribution

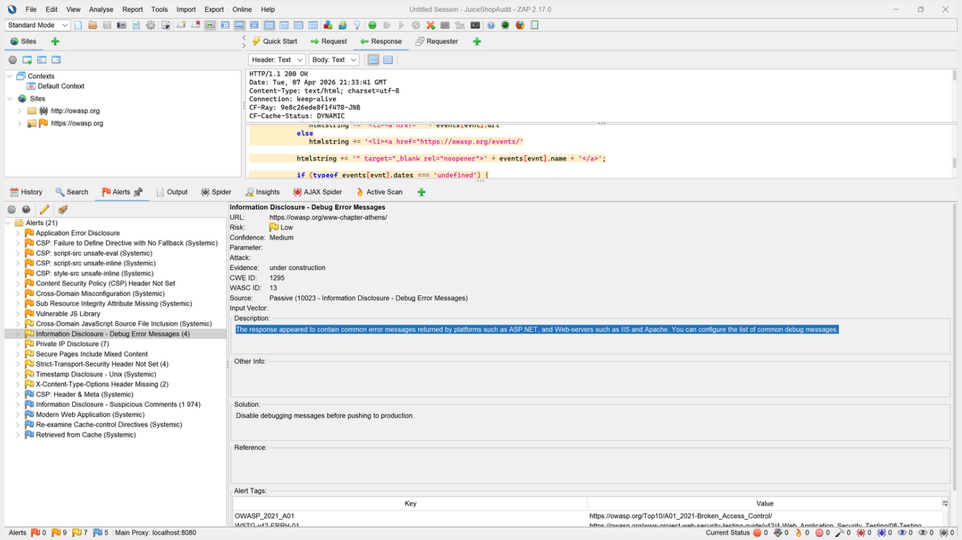


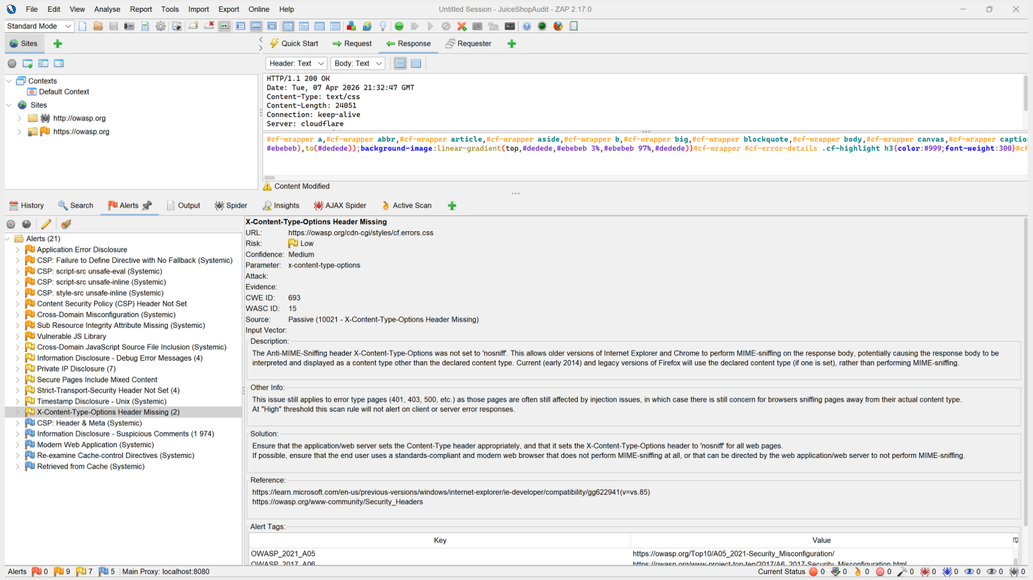
Vulnerabilities

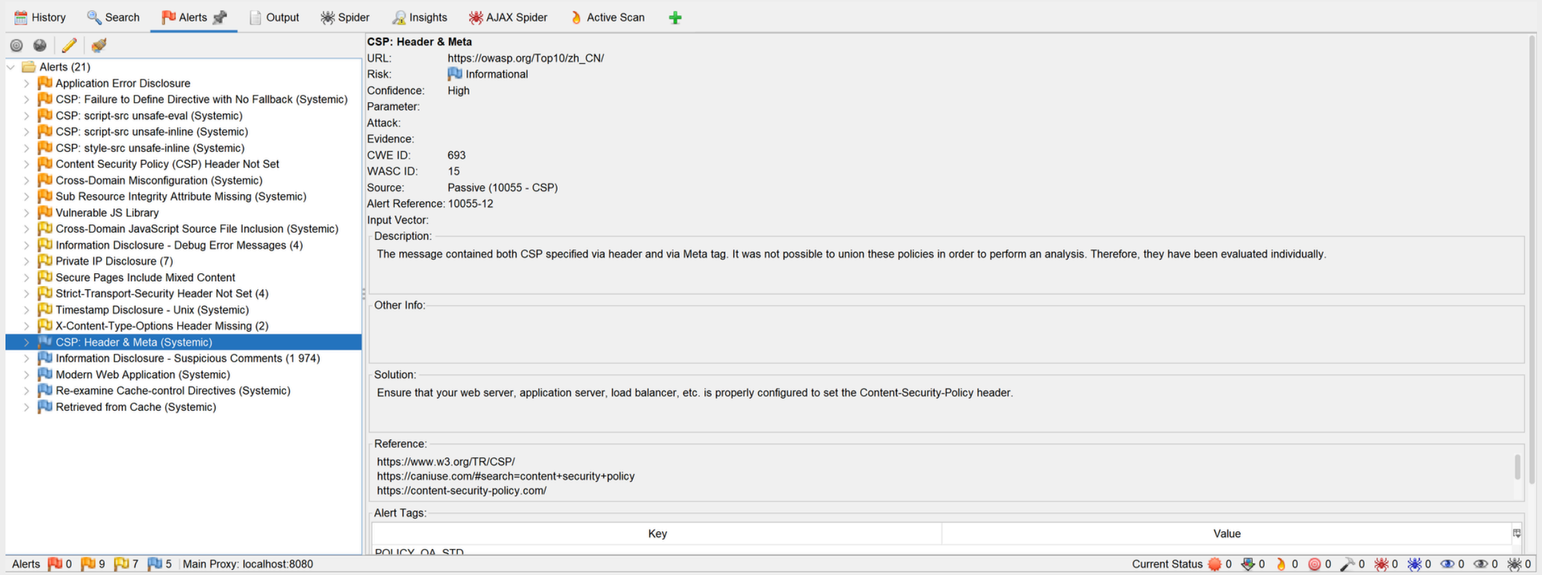
	Missing Content Security Policy
Description	The Content Security Policy (CSP) header is not properly configured. This allows the browser to execute scripts from untrusted sources, increasing the risk of cross-site scripting (XSS) attacks.
Target	OWASP Juice Shop Web Application
Risk Rating	Medium (10)
Attack techniques	Cross-Site Scripting (XSS) via injected or malicious scripts
Countermeasures	· - Implement a strict Content Security Policy (CSP) - Restrict script execution to trusted domains only - Avoid using unsafe-inline or unsafe-eval in CSP rules
Reference	OWASP Top10-A05: Security Misconfiguration
Screenshot	

	Timestamp Disclosure - Unix
Description	The application exposes timestamp information in its responses. This may allow attackers to gather information about server behavior, request timing, or system processes, which can be useful during reconnaissance.
Target	OWASP Juice Shop Web Application
Risk Rating	Low (7)
Attack techniques	Information Gathering / Reconnaissance
Countermeasures	- Avoid exposing unnecessary timestamp information in server responses - Implement proper logging controls to limit publicly visible data - Ensure sensitive system information is not included in client-facing responses
Reference	OWASP Top10-A01: Broken Access Control
Screenshot	

	Private IP Disclosure
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
Target	OWASP Juice Shop Web Application
Risk Rating	Low (7)
Attack techniques	Information Gathering
Countermeasures	- Avoid exposing internal IP addresses in responses or scripts - Use proper network configuration and masking - Remove sensitive information from client-side code and headers
Reference	OWASP Top10- A01 Broken Access Control
Screenshot	

	Information Disclosure
Description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.
Target	OWASP Juice Shop Web Application
Risk Rating	Low (7)
Attack Techniques	information Gathering
Countermeasures	- Disable detailed error messages in production - Configure the server to hide system information - Use generic error messages for users
Reference	OWASP Top10- A01 Broken Access Control
Screenshot	

	Missing X-Content Type Options
Description	The X-Content-Type-Options header is missing. Without it, browsers may incorrectly interpret files, potentially leading to content injection vulnerabilities.
Target	OWASP Juice Shop Web Application
Risk Rating	Low (7)
Attack Technique	MIME Type Confusion
Countermeasures	- Add the HTTP header: X-Content-Type-Options: nosniff - Configure the web server to prevent browsers from guessing file types - Ensure correct MIME types are enforced for all responses
Reference	OWASP Top10-A05: Security Misconfiguration
Screenshot	

	Missing CSP: Header & Meta
Description	The application defines Content Security Policy (CSP) in both HTTP headers and HTML meta tags, which may cause inconsistencies in policy enforcement and reduce security effectiveness.
Target	OWASP Juice Shop Web Application
Risk Rating	Information (0)
Attack Technique	Security Misconfiguration / Policy Bypass
Countermeasures	- Define CSP only in HTTP response headers - Avoid using CSP meta tags when headers are already implemented - Ensure consistent security policy across all layers of the application
Reference	OWASP Top10-A05: Security Misconfiguration
Screenshot	

CONCLUSION

A vulnerability assessment was conducted on the OWASP Juice Shop web application to identify security weaknesses in publicly accessible components using passive scanning techniques.

The assessment focused on security misconfigurations, information disclosure, and missing security headers.

A total of 6 findings were identified:

- 0 High-Risk vulnerabilities
- 1 Medium-Risk vulnerability
- 4 Low-Risk vulnerabilities
- 1 Informational finding

The most common issues were related to missing security headers and information disclosure. While no critical vulnerabilities were identified, these weaknesses could assist attackers during reconnaissance or lead to potential exploitation if left unaddressed.